EVIDENCE REPORT

Target Website	http://testphp.vulnweb.com
Prepared for	Future Interns
Prepared by	Sanita Salomon
Date	1 Mar 2026

Tools Used

Nmap	OWASP ZAP	Browser Dev Tools	Nikto

1.Nmap Scan Evidence

- Scan Command Used : nmap -sV -sC testphp.vulnweb.com

```
C:\WINDOWS\system32\cmd.exe
Microsoft Windows [Version 10.0.19045.6466]
(c) Microsoft Corporation. All rights reserved.

C:\Users\salomon>nmap -sV -sC testphp.vulnweb.com
Starting Nmap 7.94 ( https://nmap.org ) at 2026-02-21 10:09 India Standard Time
Nmap scan report for testphp.vulnweb.com (44.228.249.3)
Host is up (0.28s latency).
rDNS record for 44.228.249.3: ec2-44-228-249-3.us-west-2.compute.amazonaws.com
Not shown: 999 filtered tcp ports (no-response)
PORT   STATE SERVICE VERSION
80/tcp open  http    nginx 1.19.0
|_http-title: Site doesn't have a title (text/html; charset=UTF-8).

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 54.04 seconds
```

Figure 1.1 : Nmap Scan Output

Vulnerabilities Identified :

1. Open HTTP Port (80):
   Port 80 is open and running HTTP service, indicating unencrypted communication. This may allow Man-in-the-Middle (MITM) attacks. (Risk: Medium)
2. Server Version Disclosure:
   The scan reveals the server is running nginx 1.19.0, exposing version information that attackers may use to target known vulnerabilities. (Risk: Medium)

2.OWASP ZAP Evidence

ID	Source	Req. Timestamp	Method	URL	Code	Reason	RTT	Size Resp. Body	Highest Alert	Note	Tags
1	Proxy	2/21/26, 11:08:14 AM	GET	http://clients2.google.com/time/1/current?cup2key=9:0kM	200	OK	111 ms	79 bytes			JSON
5	Proxy	2/21/26, 11:08:15 AM	POST	https://www.googleapis.com/chromewebstore/v1.1/items	200	OK	352 ms	91 bytes	Low		JSON
10	Proxy	2/21/26, 11:08:16 AM	GET	https://www.google.com/async/folae?async=_fmt:pb	200	OK	152 ms	194 bytes			
13	Proxy	2/21/26, 11:08:16 AM	POST	https://accounts.google.com/ListAccounts?gpsia=1&sour	200	OK	205 ms	0 bytes			
15	Proxy	2/21/26, 11:08:17 AM	POST	https://android.clients.google.com/checkin	200	OK	217 ms	496 bytes	Low		
17	Proxy	2/21/26, 11:08:17 AM	POST	https://android.clients.google.com/c2dm/register3	301	Moved Permanently	137 ms	25 bytes	Low		
19	Proxy	2/21/26, 11:08:20 AM	GET	http://testphp.vulnweb.com/	200	OK	485 ms	4,958 bytes	Medium		Form, Object, Script, MailT...
21	Proxy	2/21/26, 11:08:17 AM	POST	https://android.clients.google.com/c2dm/register3	200	OK	3.81 s	137 bytes	Low		
22	Proxy	2/21/26, 11:08:20 AM	GET	http://testphp.vulnweb.com/style.css	200	OK	488 ms	5,482 bytes			
25	Proxy	2/21/26, 11:08:17 AM	POST	https://android.clients.google.com/c2dm/register3	200	OK	3.75 s	137 bytes			
27	Proxy	2/21/26, 11:08:24 AM	POST	https://optimizationguide-pa.googleapis.com/v1:GetModel	200	OK	165 ms	9,880 bytes	Low		
29	Proxy	2/21/26, 11:08:26 AM	GET	https://optimizationguide-pa.googleapis.com/downloads?r	200	OK	324 ms	18,358 bytes	Medium		

Figure 2.1 Owasp Zap Alerts - Part 1

ID	Source	Req. Timestamp	Method	URL	Code	Reason	RTT	Size Resp. Body	Highest Alert	Note	Tags
29	Proxy	2/21/26, 11:08:26 AM	GET	https://optimizationguide-pa.googleapis.com/downloads?r	200	OK	324 ms	18,358 bytes	Medium		
30	Proxy	2/21/26, 11:08:26 AM	GET	https://optimizationguide-pa.googleapis.com/downloads?r	200	OK	1.01 s	265,059 bytes			Comment
31	Proxy	2/21/26, 11:08:26 AM	GET	https://optimizationguide-pa.googleapis.com/downloads?r	200	OK	1.84 s	883,094 bytes			Comment
32	Proxy	2/21/26, 11:08:28 AM	GET	https://optimizationguide-pa.googleapis.com/downloads?r	200	OK	107 ms	18,806 bytes			
33	Proxy	2/21/26, 11:08:27 AM	GET	https://optimizationguide-pa.googleapis.com/downloads?r	200	OK	2.85 s	2,200,227 bytes			Comment
34	Proxy	2/21/26, 11:08:28 AM	GET	https://optimizationguide-pa.googleapis.com/downloads?r	200	OK	3.33 s	2,992,963 bytes			Comment
35	Proxy	2/21/26, 11:08:31 AM	GET	https://optimizationguide-pa.googleapis.com/downloads?r	200	OK	181 ms	4,879 bytes			
36	Proxy	2/21/26, 11:08:30 AM	GET	https://optimizationguide-pa.googleapis.com/downloads?r	200	OK	3.64 s	2,746,900 bytes			Comment
37	Proxy	2/21/26, 11:08:33 AM	GET	https://optimizationguide-pa.googleapis.com/downloads?r	200	OK	1.08 s	118,577 bytes			Comment
38	Proxy	2/21/26, 11:08:17 AM	GET	https://testphp.vulnweb.com/	504	Gateway Timeout	20.01 s	182 bytes			
40	Proxy	2/21/26, 11:08:45 AM	POST	https://android.clients.google.com/c2dm/register3	301	Moved Permanently	286 ms	25 bytes			
41	Proxy	2/21/26, 11:09:33 AM	POST	https://android.clients.google.com/c2dm/register3	301	Moved Permanently	862 ms	25 bytes			
42	Proxy	2/21/26, 11:09:14 AM	POST	https://update.googleapis.com/service/update2/json?cup2	504	Gateway Timeout	1.05 min	333 bytes			

Figure 2.2 Owasp Zap Alerts- Part 2

ID	Source	Req. Timestamp	Method	URL	Code	Reason	RTT	Size Resp. Body	Highest Alert	Note	Tags
34	Proxy	2/21/26, 11:08:28 AM	GET	https://optimizationguide-pa.googleapis.com/downloads/h	200	OK	3.33 s	2,992,950 bytes			Comment
35	Proxy	2/21/26, 11:08:31 AM	GET	https://optimizationguide-pa.googleapis.com/downloads/h	200	OK	181 ms	4,879 bytes			
36	Proxy	2/21/26, 11:08:30 AM	GET	https://optimizationguide-pa.googleapis.com/downloads/h	200	OK	3.64 s	2,746,900 bytes			Comment
37	Proxy	2/21/26, 11:08:33 AM	GET	https://optimizationguide-pa.googleapis.com/downloads/h	200	OK	1.08 s	118,577 bytes			Comment
38	Proxy	2/21/26, 11:08:17 AM	GET	https://testphp.vulnweb.com/	504	Gateway Timeout	20.01 s	182 bytes			
40	Proxy	2/21/26, 11:08:45 AM	POST	https://android.clients.google.com/c2dm/register3	301	Moved Permanently	286 ms	25 bytes			
41	Proxy	2/21/26, 11:09:33 AM	POST	https://android.clients.google.com/c2dm/register3	301	Moved Permanently	882 ms	25 bytes			
42	Proxy	2/21/26, 11:09:14 AM	POST	https://update.googleapis.com/service/update2/json?cup2	504	Gateway Timeout	1.05 min	333 bytes			
46	Proxy	2/21/26, 11:10:17 AM	POST	http://update.googleapis.com/service/update2/json?cup2k	200	OK	447 ms	4,238 bytes			JSON
50	Proxy	2/21/26, 11:11:19 AM	POST	https://android.clients.google.com/c2dm/register3	301	Moved Permanently	155 ms	25 bytes			
51	Proxy	2/21/26, 11:14:55 AM	POST	https://android.clients.google.com/c2dm/register3	301	Moved Permanently	265 ms	25 bytes			
52	Proxy	2/21/26, 11:17:27 AM	POST	https://chromewebstore.googleapis.com/v2/items/-/store.	200	OK	375 ms	0 bytes	Low		
57	Proxy	2/21/26, 11:22:02 AM	POST	https://android.clients.google.com/c2dm/register3	301	Moved Permanently	551 ms	25 bytes			

Figure 2.3 Owasp Zap Alerts- Part 3

Vulnerabilities Identified :

1. Missing Security Headers:
   ZAP detected missing headers such as X-Frame-Options and Content-Security-Policy, increasing the risk of clickjacking and XSS attacks. (Risk: Medium)
2. Form/Input Validation Issues:
   Several forms do not properly validate user input, which may lead to SQL Injection or XSS attacks. (Risk: Medium)
3. Minor Cookie Security Issues:
   Cookies are not marked as Secure or HttpOnly, increasing the risk of session hijacking. (Risk: Low)

3.Browser Developer Tools Evidence

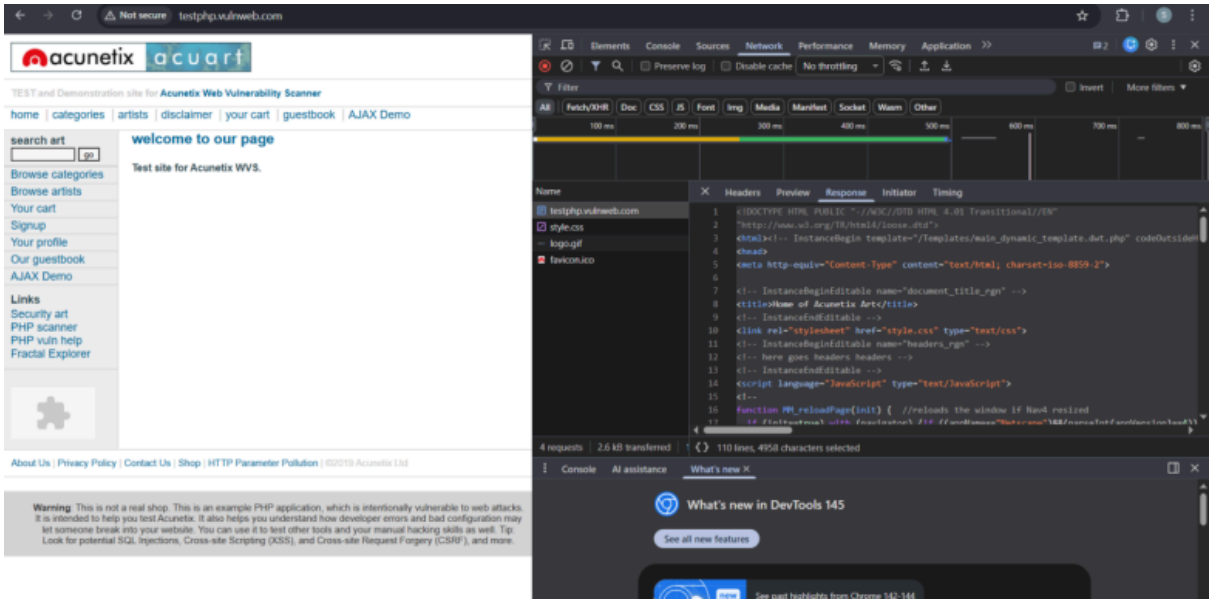

Figure 3.1 Browser Developer Tools Showing HTTP Response Headers and HTML Source Code

Vulnerabilities Identified:

1. Server-Side Technology Exposure:
   The HTTP response headers and the HTML source code disclose details about the server technologies and configuration being used. Revealing this technical information can help attackers identify the underlying platform and carry out more targeted exploitation attempts. (Risk:Low–Medium)
2. Possible XSS / Weak Input Validation:
   Pages such as search.php, login.php, and guestbook.php do not clearly demonstrate proper input sanitization mechanisms. If user input is not adequately validated or filtered, it increases the risk of Cross-Site Scripting (XSS) or other injection-based attacks. (Risk:Medium)
3. CSRF and Session Management Weaknesses:
   The website forms do not appear to include CSRF protection tokens. Without these tokens, attackers may trick authenticated users into performing unauthorized actions, leading to potential session security issues. (Risk:Medium)
4. Use of Deprecated Components (Flash):
   The website contains Flash-based elements, which are deprecated and no longer supported. Since Flash has a history of security vulnerabilities, its use may introduce known weaknesses into the application. (Risk:Low)
5. Absence of Important Security Headers:
   Key HTTP security headers such as Content Security Policy (CSP), HTTP Strict Transport Security (HSTS), and X-Frame-Options are missing. The absence of these headers weakens browser-side security protections and may expose users to various web-based attacks. (Risk:Medium)
6. Unsecured HTTP Communication:
   The website operates using HTTP instead of HTTPS, meaning the data transmitted between users and the server is not encrypted. This makes the communication vulnerable to interception or Man-in-the-Middle (MITM) attacks. (Risk:Medium)
7. Information Leakage through HTML Comments:
   The HTML source code includes comments that reveal internal notes about vulnerabilities. Although this may not directly result in exploitation, such exposed information could assist attackers in a real-world scenario. (Risk:Low–Informational)

4.Nikto Scan Evidence

Scan Command Used:nikto -h http://testphp.vulnweb.com

```
┌──(kali㉿kali)-[~]
└─$ nikto -h http://testphp.vulnweb.com
- Nikto v2.5.0
---------------------------------------------------------------------------
+ Target IP:          44.228.249.3
+ Target Hostname:    testphp.vulnweb.com
+ Target Port:        80
+ Start Time:         2026-02-21 03:25:26 (GMT-5)
---------------------------------------------------------------------------
+ Server: nginx/1.19.0
+ /: Retrieved x-powered-by header: PHP/5.6.40-38+ubuntu20.04.1+deb.sury.org+1.
+ /: The anti-clickjacking X-Frame-Options header is not present. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/
+ /: The X-Content-Type-Options header is not set. This could allow the user agent to render the content of the site in a
sing-content-type-header/
+ /clientaccesspolicy.xml contains a full wildcard entry. See: https://docs.microsoft.com/en-us/previous-versions/window
+ /clientaccesspolicy.xml contains 12 lines which should be manually viewed for improper domains or wildcards. See: http
+ /crossdomain.xml contains a full wildcard entry. See: http://jeremiahgrossman.blogspot.com/2008/05/crossdomainxml-invi
+ ERROR: Error limit (20) reached for host, giving up. Last error: error reading HTTP response
+ Scan terminated: 20 error(s) and 6 item(s) reported on remote host
+ End Time:           2026-02-21 03:27:48 (GMT-5) (142 seconds)
---------------------------------------------------------------------------
+ 1 host(s) tested
```

Figure 4.1 Nikto Scan Output

Vulnerabilities Identified :

1. Server Version Disclosure:
   The versions of the web server and PHP are publicly accessible. Exposing this information enables attackers to identify the specific software versions in use and search for known vulnerabilities or exploits associated with those versions. (Risk:Medium)
2. Missing X-Frame-Options Header:
   The X-Frame-Options security header has not been configured. Without this protection, the website is susceptible to clickjacking attacks, where malicious websites can embed the page in a frame and trick users into performing unintended actions. (Risk:Medium)
3. Missing X-Content-Type-Options Header:
   MIME type sniffing protection is not enabled due to the absence of the X-Content-Type-Options header. This may allow browsers to incorrectly interpret file types, potentially leading to the execution of malicious content. (Risk:Medium)
4. Insecure clientaccesspolicy.xml Configuration:
   The clientaccesspolicy.xml file contains a wildcard (*) domain entry that allows unrestricted cross-domain access. Such a permissive configuration increases the risk of unauthorized domains interacting with the application. (Risk:Medium)
5. Insecure crossdomain.xml Configuration:
   The crossdomain.xml file is configured with a wildcard domain policy, permitting access from any external domain. This broad access setting raises the risk of cross-site attacks and unauthorized data exposure. (Risk:Medium)

Conclusion

The vulnerability assessment conducted on testphp.vulnweb.com identified multiple security issues, including server information disclosure, missing security headers, input validation weaknesses, and insecure configurations.

The findings were identified using Nmap, OWASP ZAP, Browser Developer Tools, and Nikto, with supporting evidence provided in the screenshots above. Although the target site is intentionally vulnerable for testing purposes, these issues would pose significant security risks in a real-world production environment.

Prepared by: **Sanita Salomon**

Date Reported: **1 Mar 2026**